Assignment- 1

Black Box Penetration Testing

On

demo.testfire.net

By: - Parth Pathak

Scope of Work: -

This assignment covers the remote penetration testing of demo.testfire.net. The assignment was carried out from a black box perspective, with the only supplied information being the domain name. No other information was assumed at the start of the assignment.

I used the following tools only:

- Burp Suite (Proxy)

Summary of Findings: -

The findings below use OWASP Top 10:2025 categories. Functional issues and other observations are included separately in the same table. Counts represent distinct recorded instances, not confirmed vulnerabilities alone.

Category	Vulnerability / Observation	Count
A01:2025 Broken Access Control	Public exposure of a confidential draft	1
A02:2025 Security Misconfiguration	Server banner disclosure (informational)	1
	Unrecognised Host header accepted (requires validation)	1
A05:2025 Injection	Reflected XSS	3
	SQL injection with authentication bypass	1
A06:2025 Insecure Design	Missing server side transfer validation (requires validation)	1
A07:2025 Authentication Failures	Weak administrator credentials	1
A10:2025 Mishandling of Exceptional Conditions	Verbose exception and stack trace disclosure	2
Functional Issues Non-security	Input validation: unsupported language value	1
	User management: user or account creation not reflected	1
	Account display: test user account summary unavailable	1

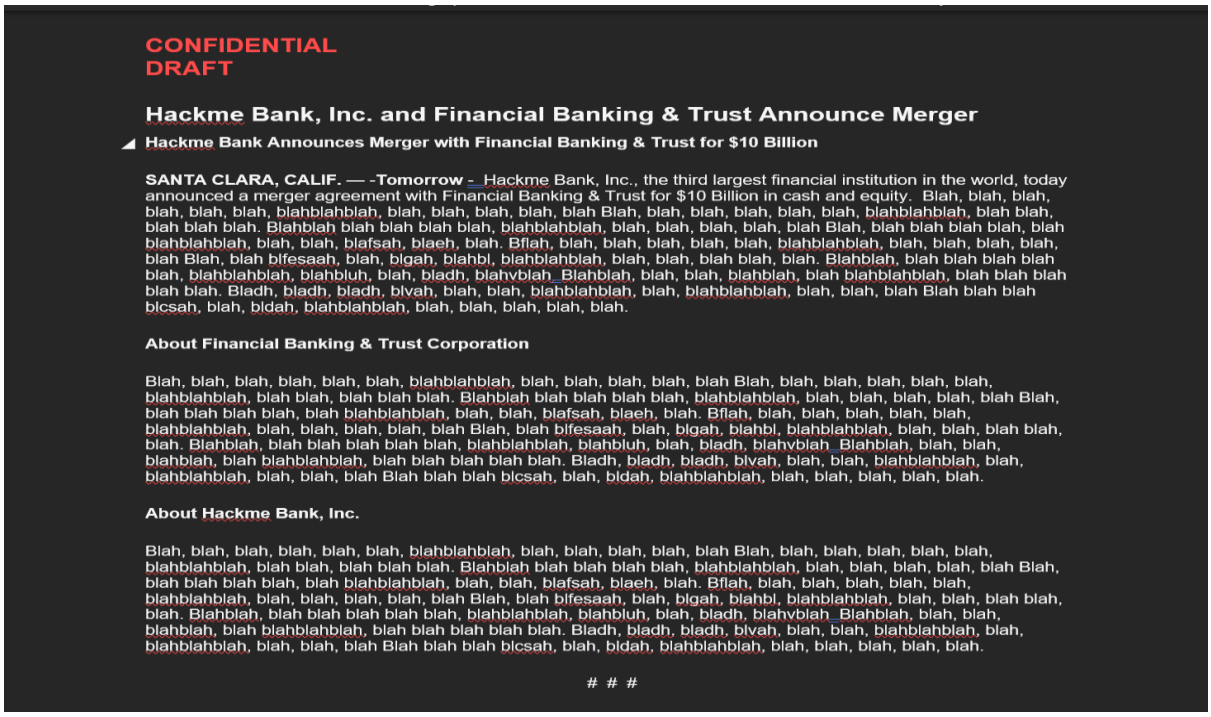
Category	Vulnerability / Observation	Count
	Survey workflow: continues after No selection	1
	Content mapping: mismatched press releases	1
	Form submission: email button has no visible effect	1
	Navigation: broken or unavailable links	4
Other Observations No established vulnerability	Error response: generic response to malformed content	1
	Path metadata: personal name in a broken document URL	1
	Password field: copying and pasting permitted	1
Total	**All recorded findings and observations**	**24**

Total: 24 recorded instances. This includes 8 confirmed security findings, 3 observations requiring validation, 2 informational observations, 10 functional issues, and 1 item that is not a vulnerability. **SQL injection** and its authentication bypass impact are counted once. OWASP reference: https://top10.owasp.org/2025/

1. Public exposure of a confidential draft:-

Classification: A01:2025 Broken Access Control | Confirmed

The /pr/ directory was reported to allow directory listing. The document https://demo.testfire.net/pr/Draft.rtf was accessible and displayed a **confidential draft** and contact details. Public access to material marked confidential supports a broken access control finding. Directory listing is a contributing A02:2025 Security Misconfiguration issue within the same finding.



CONFIDENTIAL
DRAFT

Hackme Bank, Inc. and Financial Banking & Trust Announce Merger

Hackme Bank Announces Merger with Financial Banking & Trust for $10 Billion

SANTA CLARA, CALIF. — -Tomorrow - Hackme Bank, Inc., the third largest financial institution in the world, today announced a merger agreement with Financial Banking & Trust for $10 Billion in cash and equity. Blah, blah, blah, blah, blah, blah, blahblahblah, blah, blah, blah, blah, blah Blah, blah, blah, blah, blah, blah, blahblahblah, blah blah, blah blah blah. Blahblah blah blah blah blah, blahblahblah, blah, blah, blah, blah, blah Blah, blah blah blah blah, blah blahblahblah, blah, blah, blafsah, blaeh, blah. Bflah, blah, blah, blah, blah, blah, blahblahblah, blah, blah, blah, blah, blah Blah, blah blfesaah, blah, blgah, blahbl, blahblahblah, blah, blah, blah blah, blah. Blahblah, blah blah blah blah blah, blahblahblah, blahbluh, blah, bladh, blahvblah Blahblah, blah, blah, blahblah, blah blahblahblah, blah blah blah blah blah blah. Bladh, bladh, bladh, blvah, blah, blah, blahblahblah, blah, blahblahblah, blah, blah, blah Blah blah blah blah blah, blah, bldah, blahblahblah, blah, blah, blah, blah, blah.

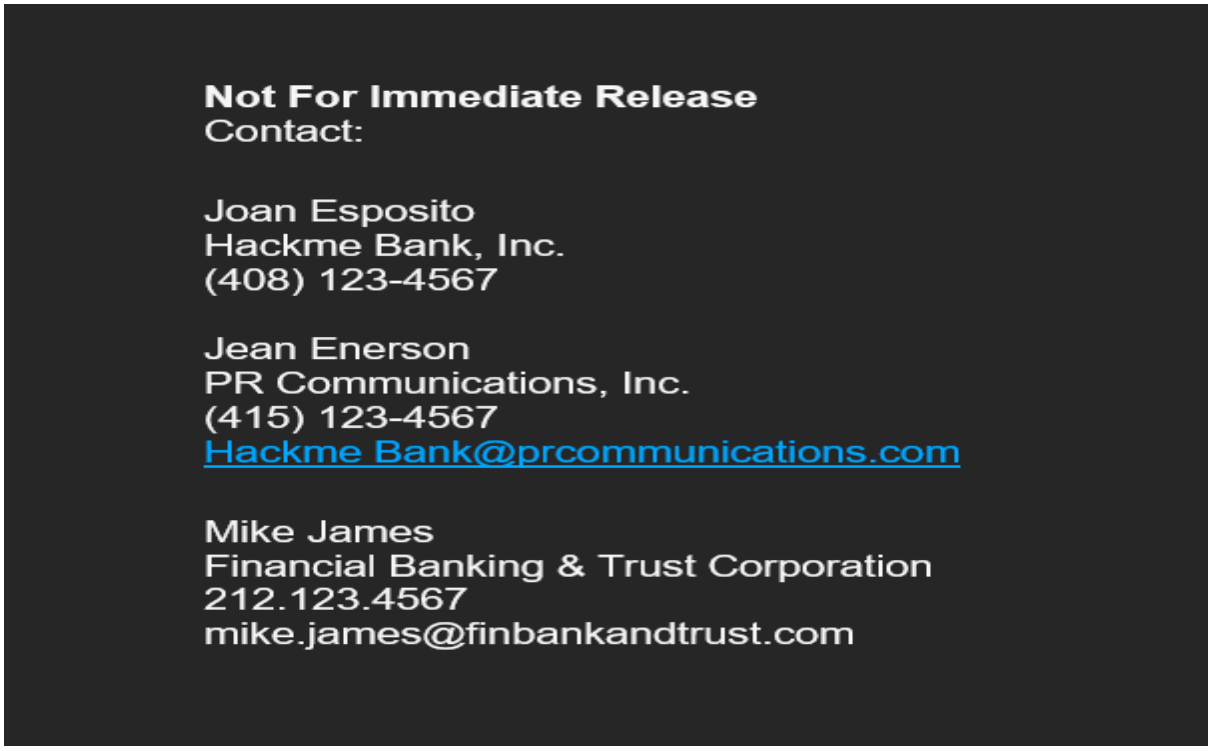
About Financial Banking & Trust Corporation

Blah, blah, blah, blah, blah, blah, blahblahblah, blah, blah, blah, blah, blah Blah, blah, blah, blah, blah, blah, blahblahblah, blah blah, blah blah blah. Blahblah blah blah blah blah, blahblahblah, blah, blah, blah, blah, blah Blah, blah blah blah, blah blahblahblah, blah, blah, blafsah, blaeh, blah. Bflah, blah, blah, blah, blah, blah, blahblahblah, blah, blah, blah, blah, blah Blah, blah blfesaah, blah, blgah, blahbl, blahblahblah, blah, blah, blah blah, blah. Blahblah, blah blah blah blah blah blah, blahblahblah, blahbluh, blah, bladh, blahvblah Blahblah, blah, blah, blah, blah blahblahblah, blah blah blah blah blah. Bladh, bladh, bladh, blvah, blah, blah, blahblahblah, blah, blah, blah Blah blah blah blah blah, blah, bldah, blahblahblah, blah, blah, blah, blah, blah.

About Hackme Bank, Inc.

Blah, blah, blah, blah, blah, blah, blahblahblah, blah, blah, blah, blah, blah Blah, blah, blah, blah, blah, blah, blahblahblah, blah blah, blah blah blah. Blahblah blah blah blah blah, blahblahblah, blah, blah, blah, blah, blah Blah, blah blah blah, blah blahblahblah, blah, blah, blafsah, blaeh, blah. Bflah, blah, blah, blah, blah, blah, blahblahblah, blah, blah, blah, blah, blah Blah, blah blfesaah, blah, blgah, blahbl, blahblahblah, blah, blah, blah blah, blah. Blahblah, blah blah blah blah blah blah, blahblahblah, blahbluh, blah, bladh, blahvblah Blahblah, blah, blah, blah, blah blahblahblah, blah blah blah blah blah. Bladh, bladh, bladh, blvah, blah, blah, blahblahblah, blah, blah, blah Blah blah blah blah blah, blah, bldah, blahblahblah, blah, blah, blah, blah, blah.

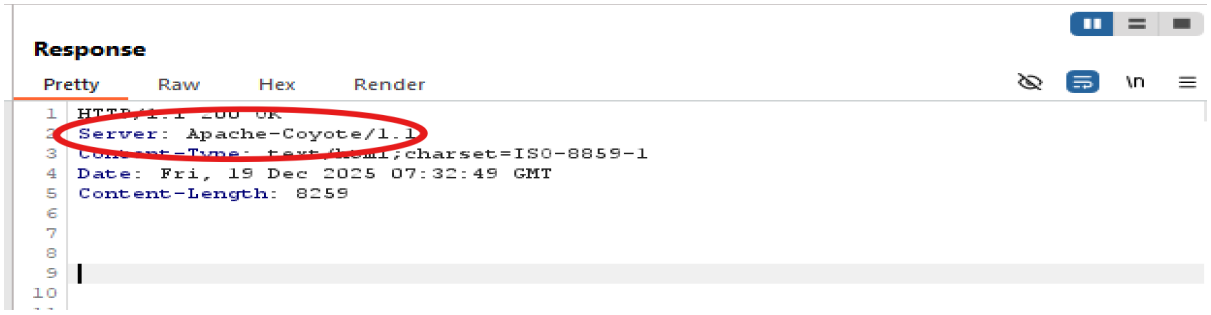
# # #



2. Server banner disclosure:-

Classification: A02:2025 Security Misconfiguration | Informational

The response headers identify the server as Apache-Coyote/1.1. This is a server banner and provides technology fingerprinting information; the HTTP/1.1 status line alone is ordinary protocol information. The banner does not establish an exploitable software version or a vulnerable component.

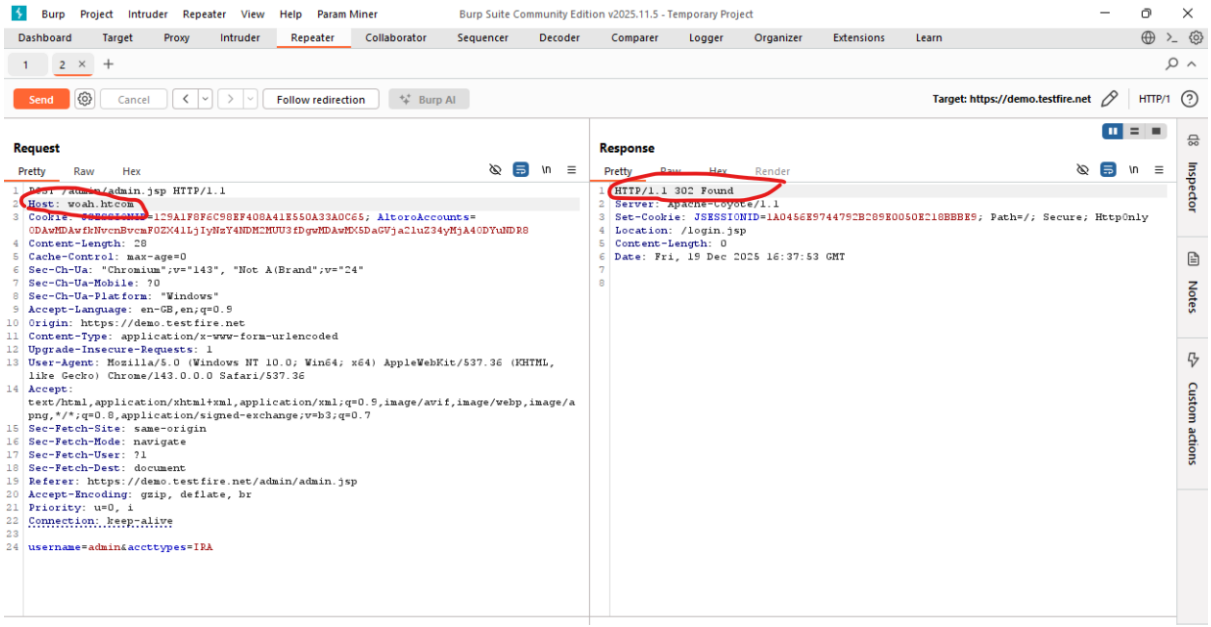


3. Unrecognised Host header accepted:-

Classification: A02:2025 Security Misconfiguration | Needs validation

A modified Host header received a server response. This suggests that host allowlisting should be checked, but a response alone does not demonstrate

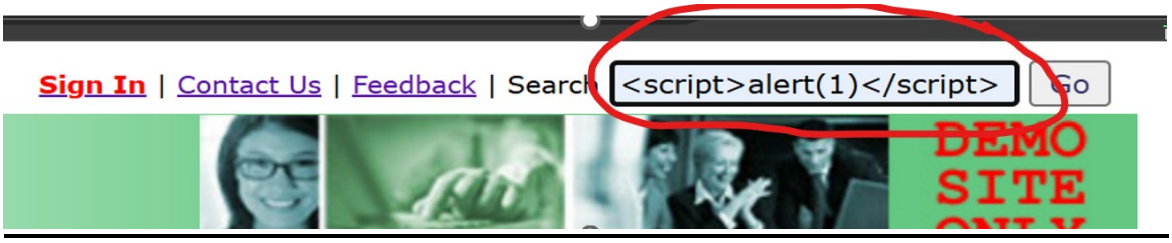
exploitable Host header injection. No password reset poisoning, attacker-controlled redirect, cache poisoning, or security-sensitive use of the supplied host was demonstrated.

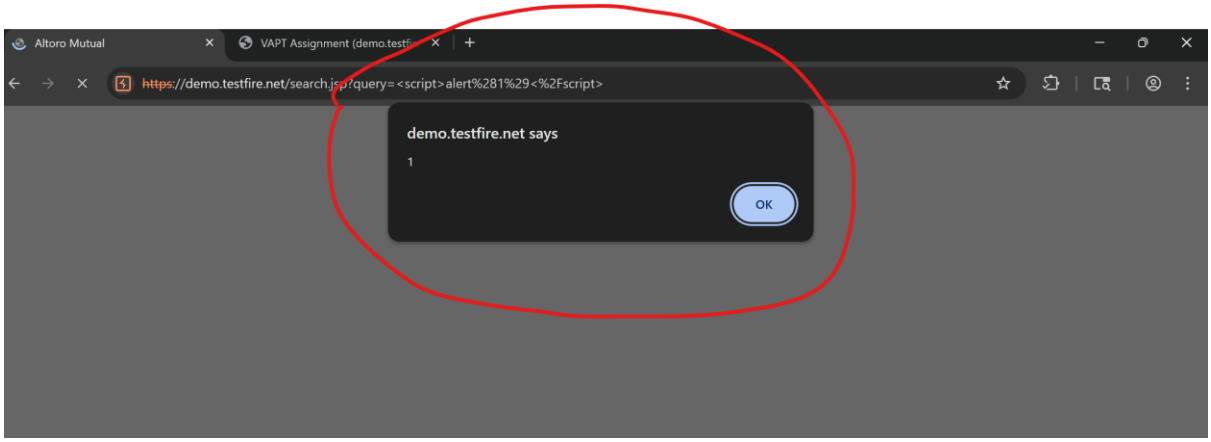


4. Reflected XSS in search:-

Classification: A05:2025 Injection | Confirmed

The search field on https://demo.testfire.net accepted <script>alert(1)</script> and the browser displayed the injected alert. This demonstrates **reflected cross-site scripting** through the search input.

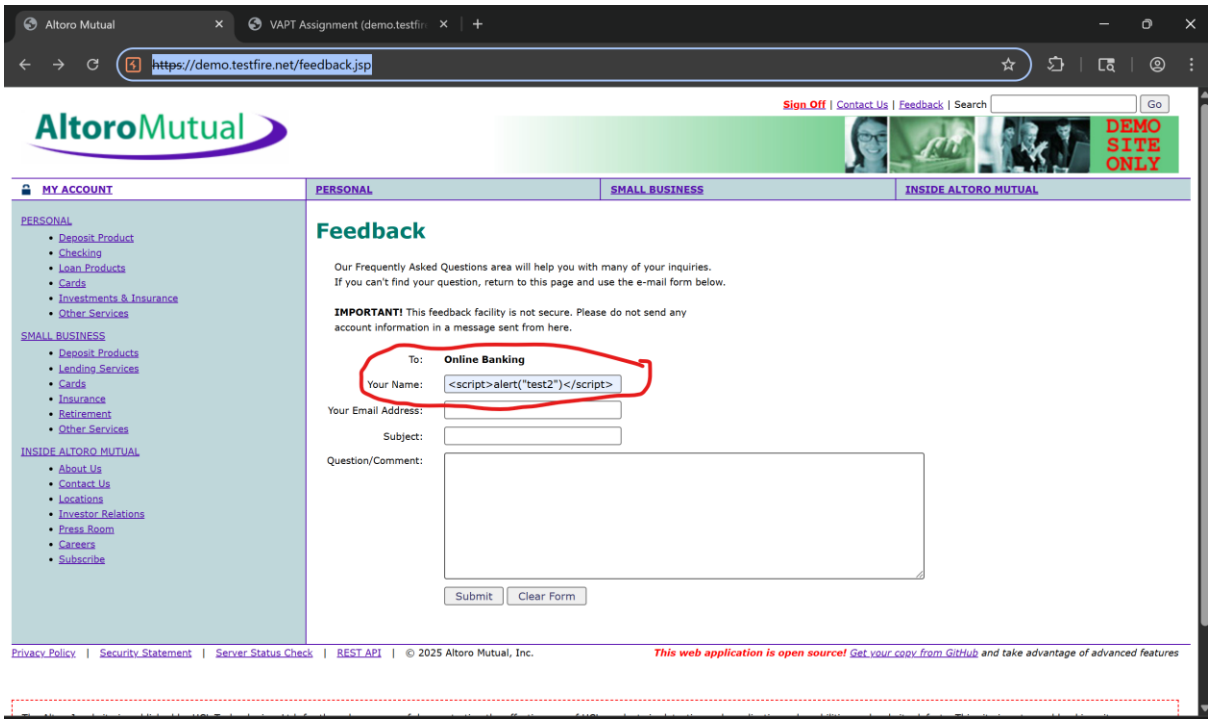


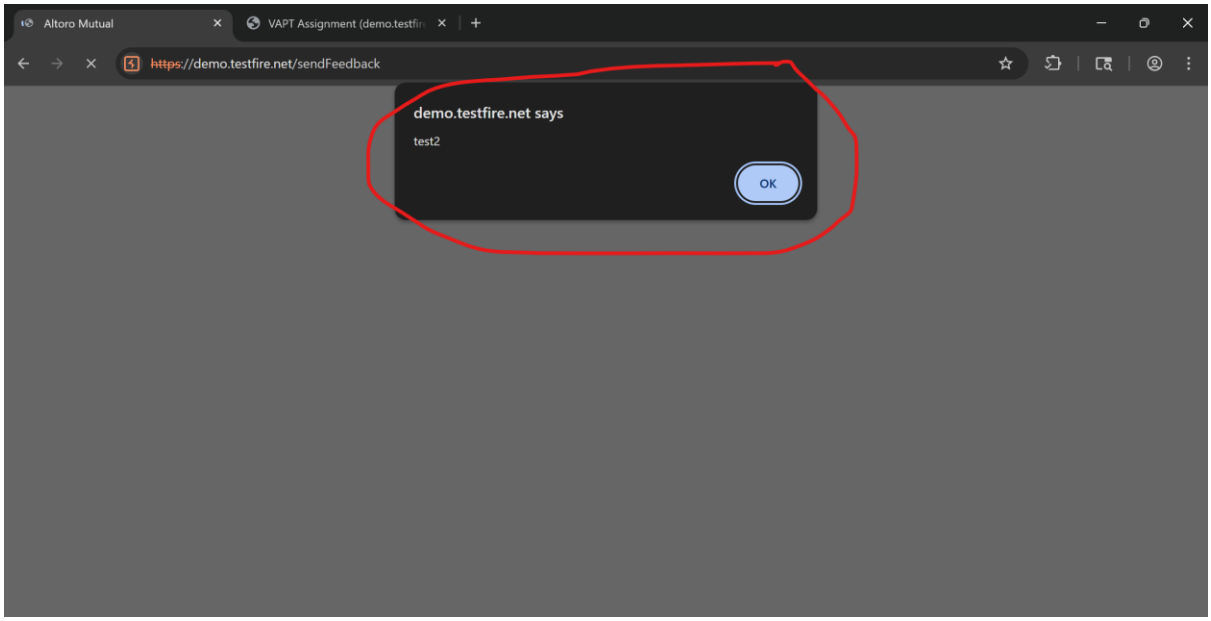


5. Reflected XSS in feedback:-

Classification: A05:2025 Injection | Confirmed

The name field on https://demo.testfire.net/feedback.jsp accepted <script>alert("test2")</script>. Submission caused the browser to execute the script and display the alert, demonstrating **reflected cross-site scripting**.

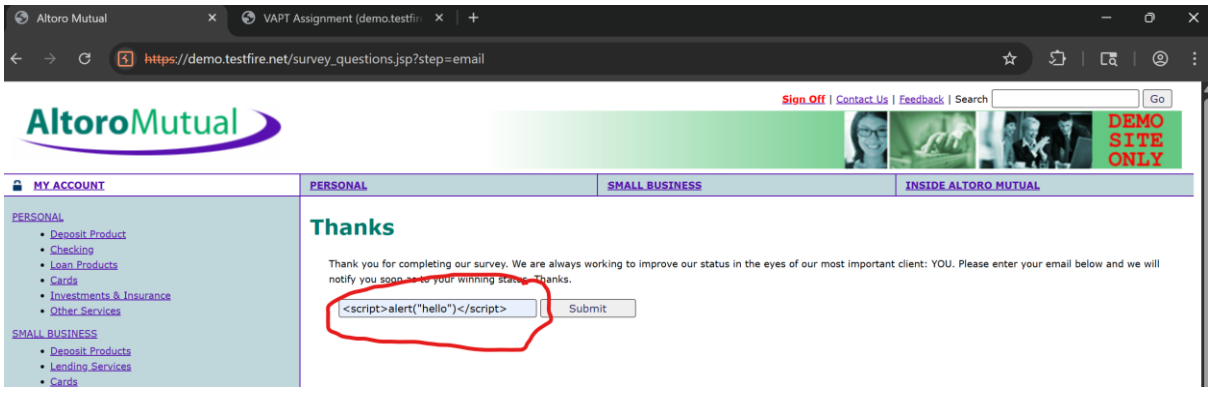


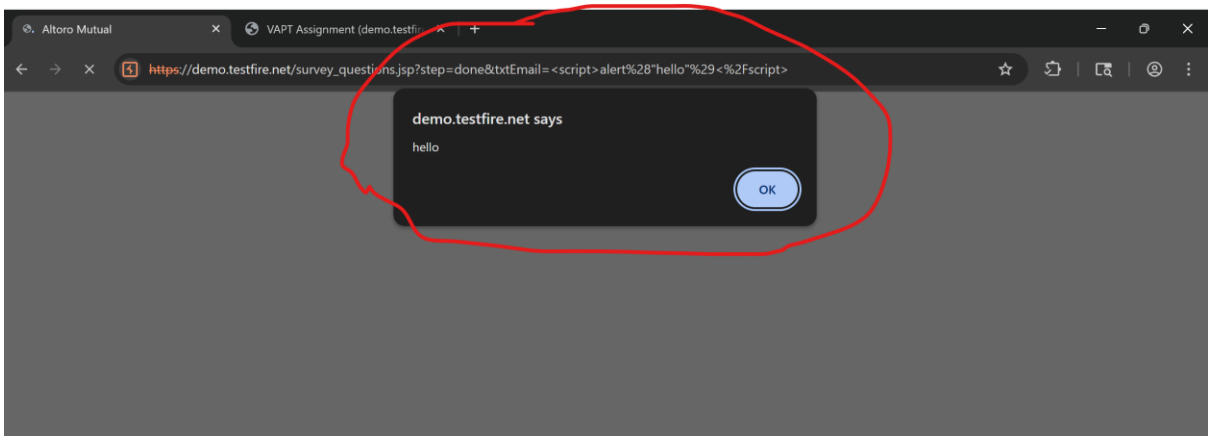


6. Reflected XSS in survey:-

Classification: A05:2025 Injection | Confirmed

The email input at https://demo.testfire.net/survey_questions.jsp?step=email accepted <script>alert("hello")</script>. The resulting alert demonstrates **reflected cross-site scripting** in the survey workflow.

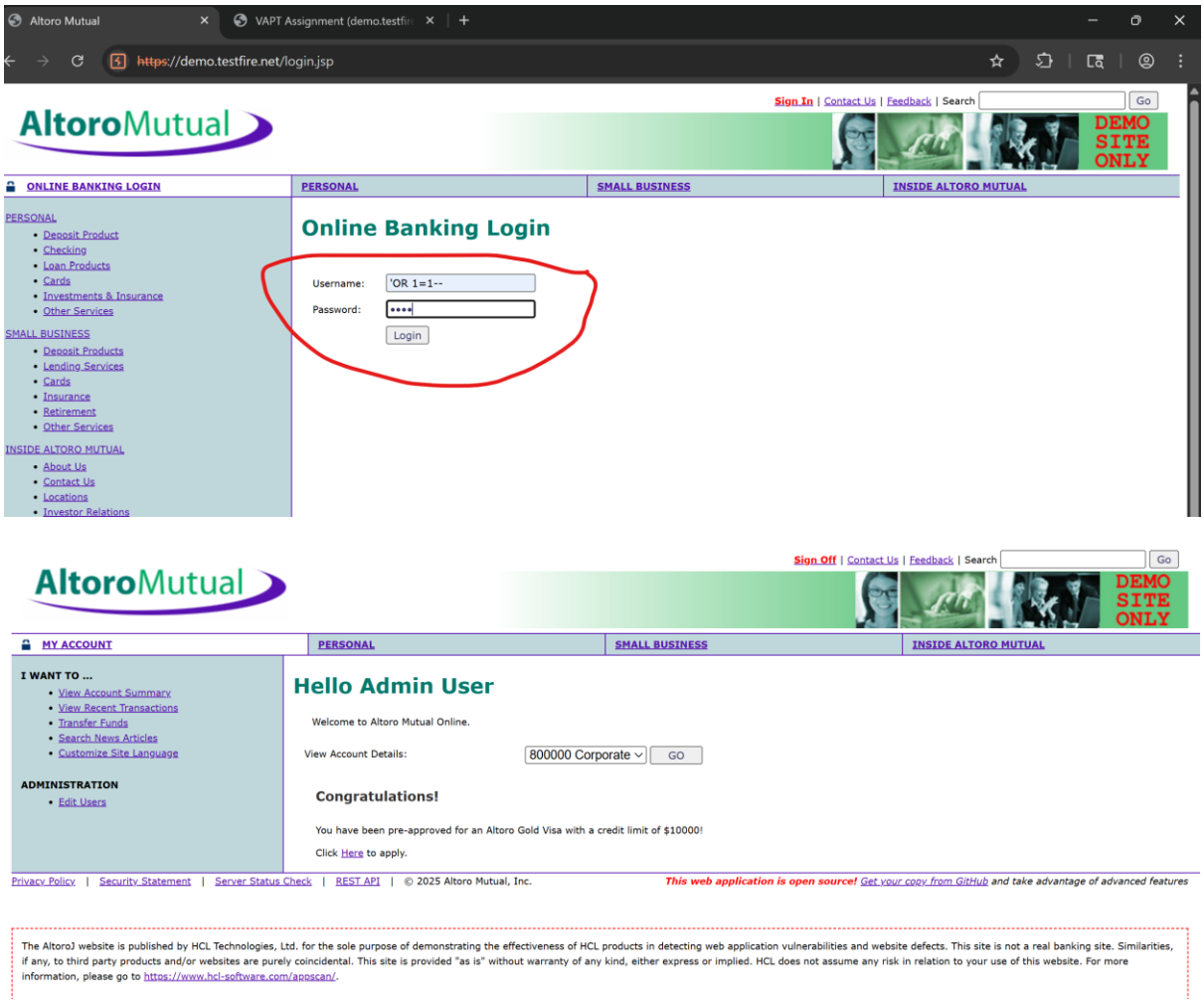




7. SQL injection authentication bypass:-

Classification: A05:2025 Injection | Confirmed

The username input on the login page was supplied with the **SQL injection** payload shown in the screenshot, with an arbitrary password. The application then opened the administrator session. **SQL injection** is the primary finding; authentication bypass is its impact and is not counted again as a separate authentication vulnerability.

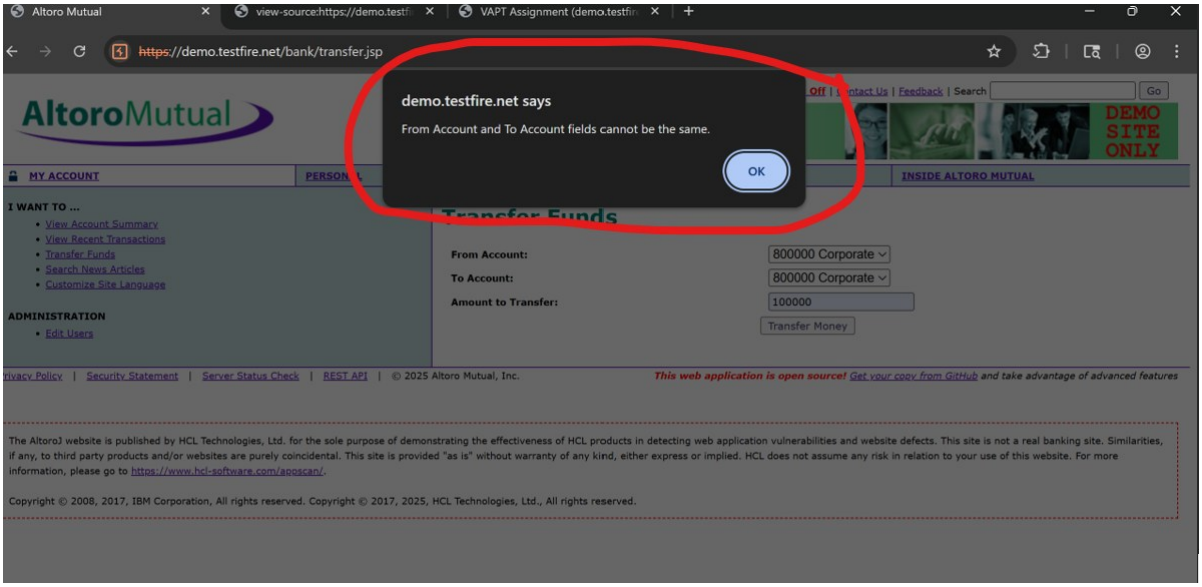


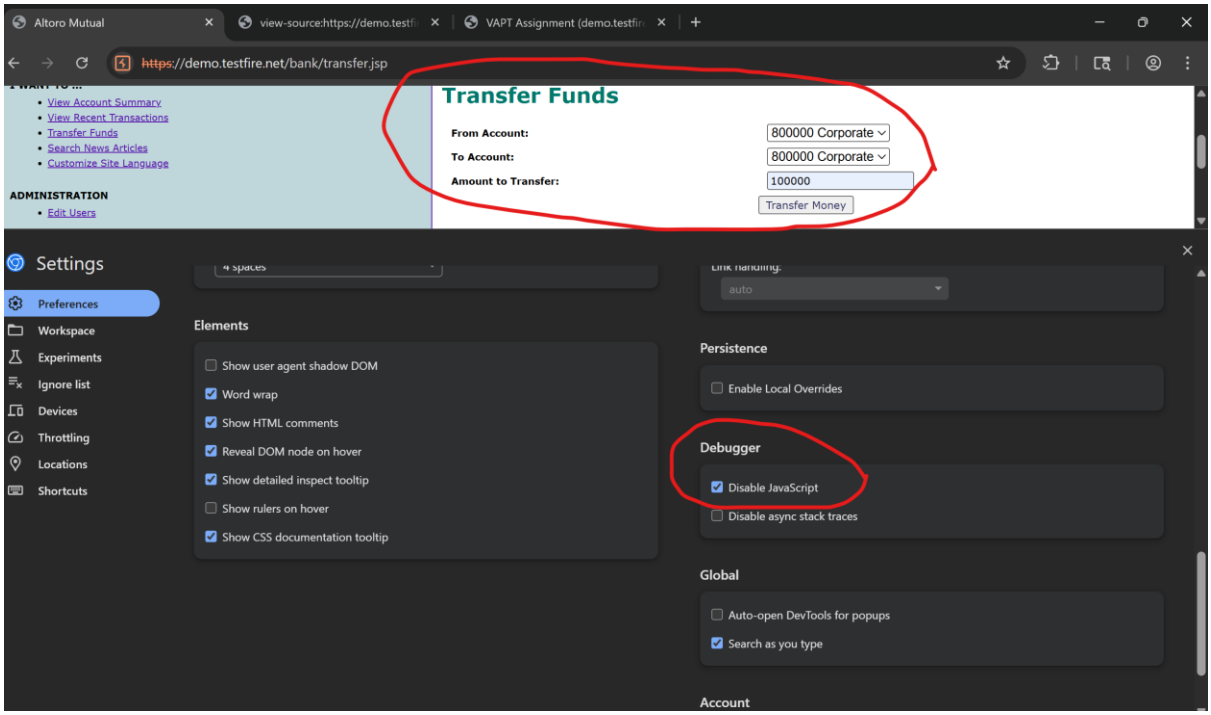
8. Missing server side transfer validation:-

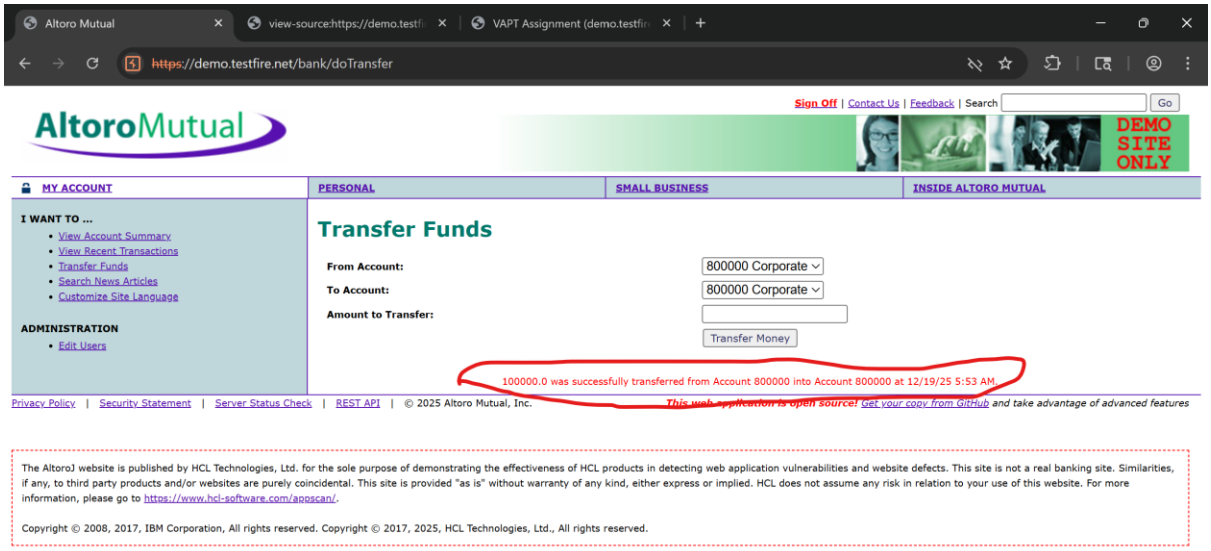
Classification: A06:2025 Insecure Design | Needs validation

On https://demo.testfire.net/bank/transfer.jsp, JavaScript normally rejected transfers with identical source and destination accounts. Disabling JavaScript allowed the request and produced a success message for a same-account

transfer. This demonstrates a **server-side business-rule validation gap**. Balance changes or financial loss were not established, so the security impact needs validation. The evidence does not establish that only administrators should be able to transfer funds.



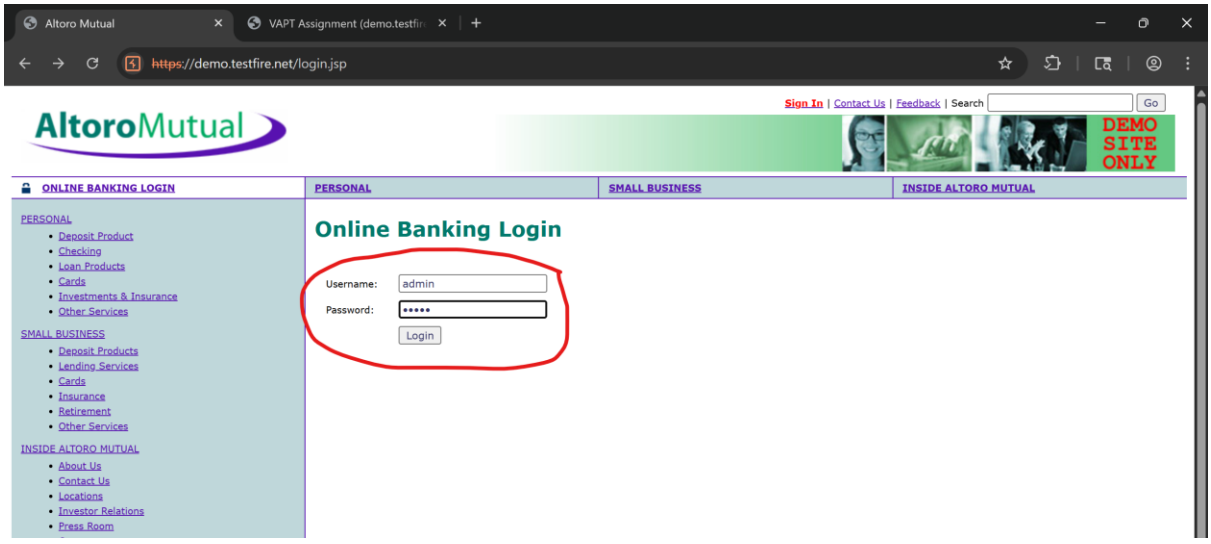


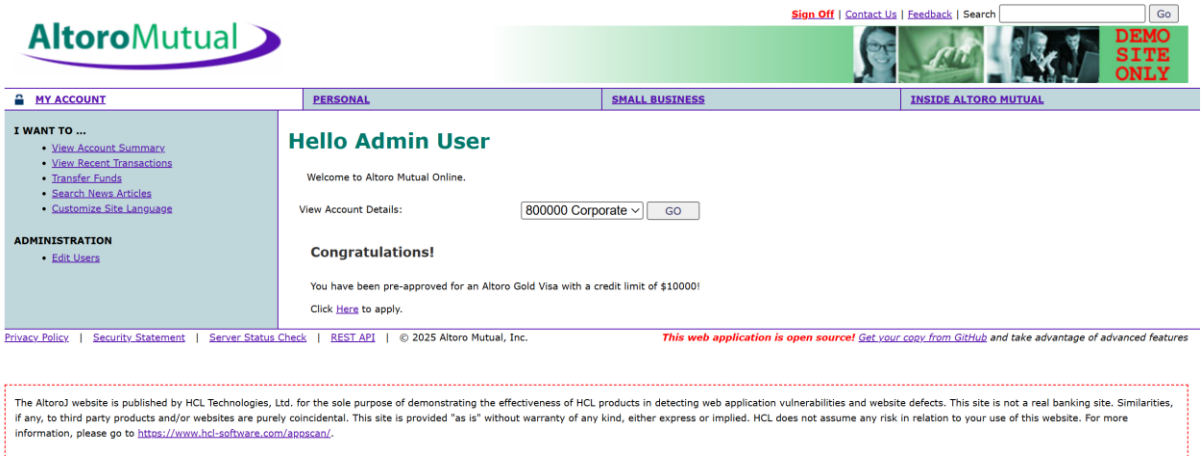


9. Weak administrator credentials:-

Classification: A07:2025 Authentication Failures | Confirmed

The login page at https://demo.testfire.net/login.jsp accepted admin as both the username and password and opened an administrator session. This demonstrates the use of a **weak, easily guessed administrator password**.

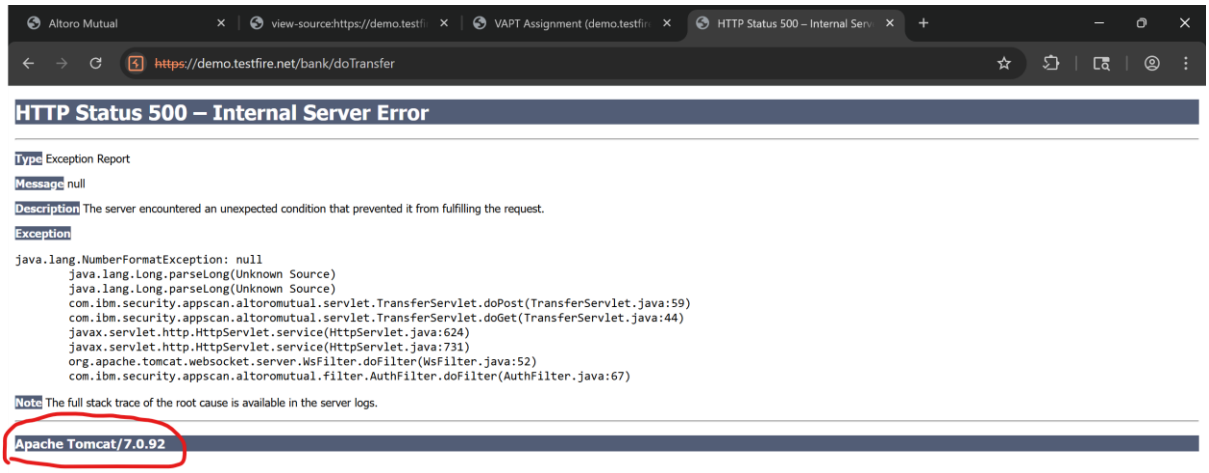




10. Verbose transfer error disclosure:-

Classification: A10:2025 Mishandling of Exceptional Conditions | Confirmed

An error response from /bank/doTransfer exposed an HTTP 500 page with a Java exception, stack trace, implementation details, and the Apache Tomcat version. This is an information disclosure through verbose exception handling. A02:2025 Security Misconfiguration is a related hardening concern; the disclosed version alone is not proof of a vulnerable component.



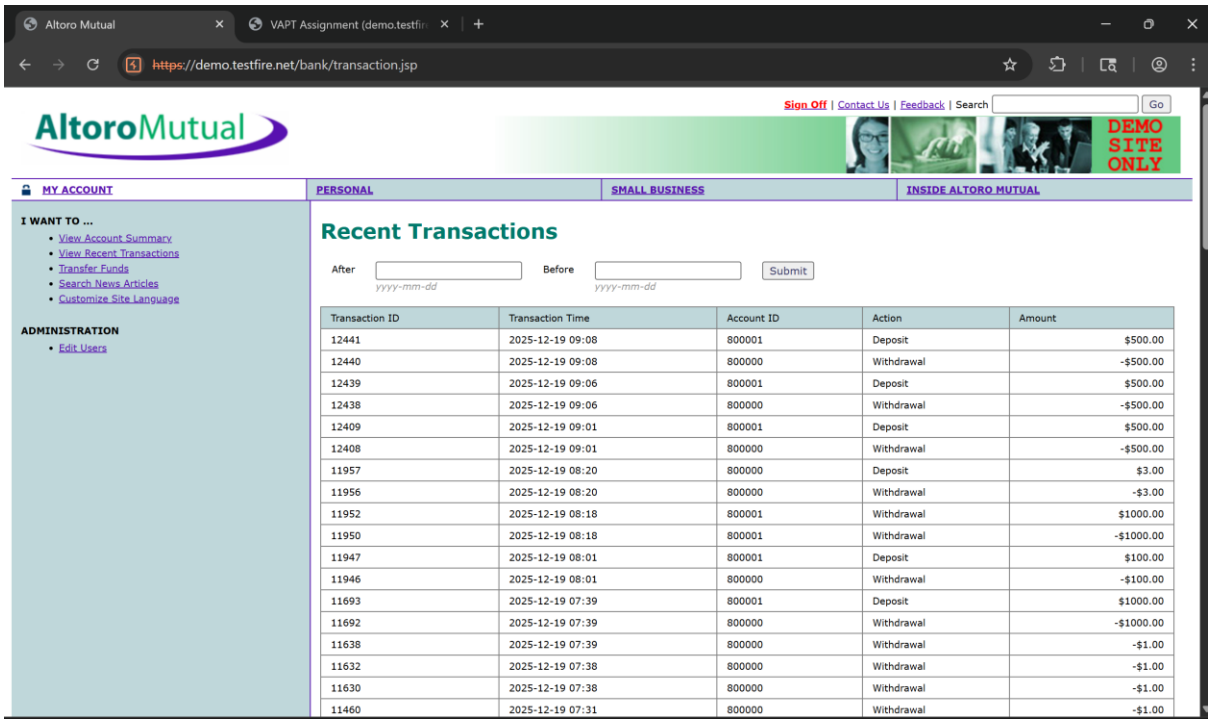
---

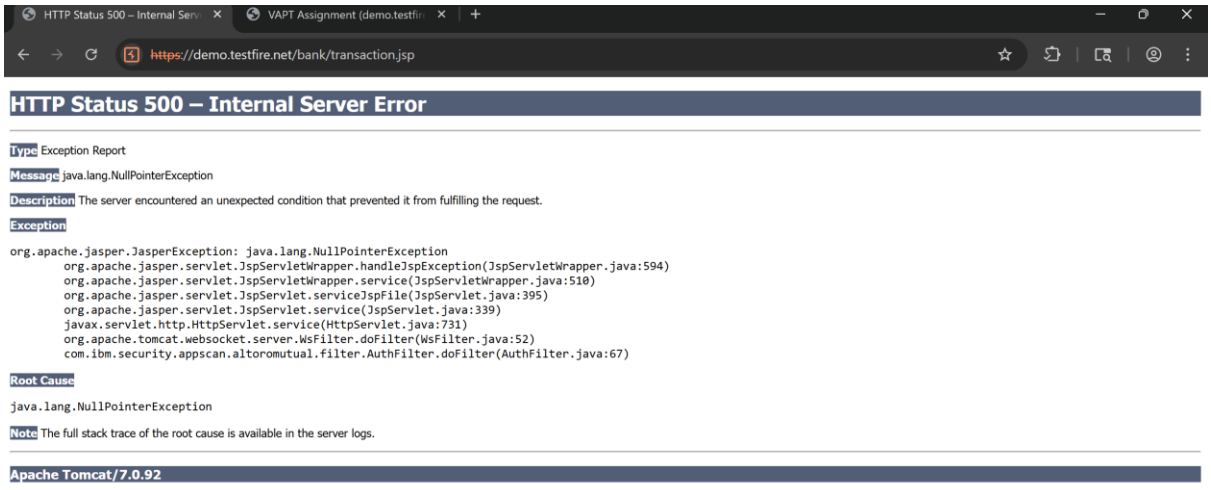
11. Unhandled exception in transaction view:-

Classification: A10:2025 Mishandling of Exceptional Conditions | Confirmed

The administrator could open https://demo.testfire.net/bank/transaction.jsp, while a non-administrator attempt produced an HTTP 500 response with a **NullPointerException** and stack trace. The demonstrated issue is an unhandled

exception and information disclosure. The evidence does not show a user gaining unauthorised access, so it does not establish broken access control.



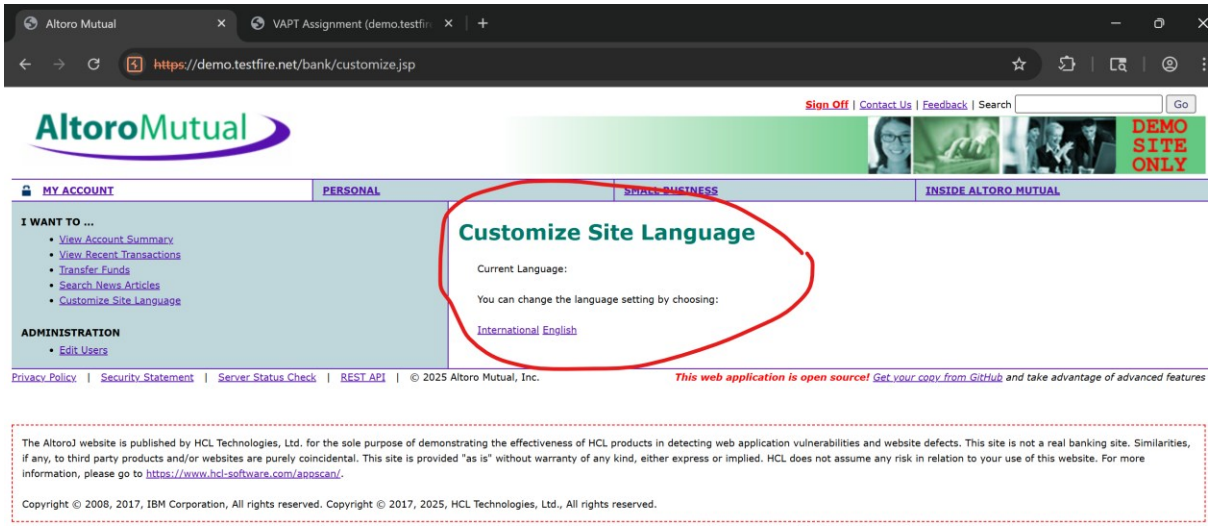


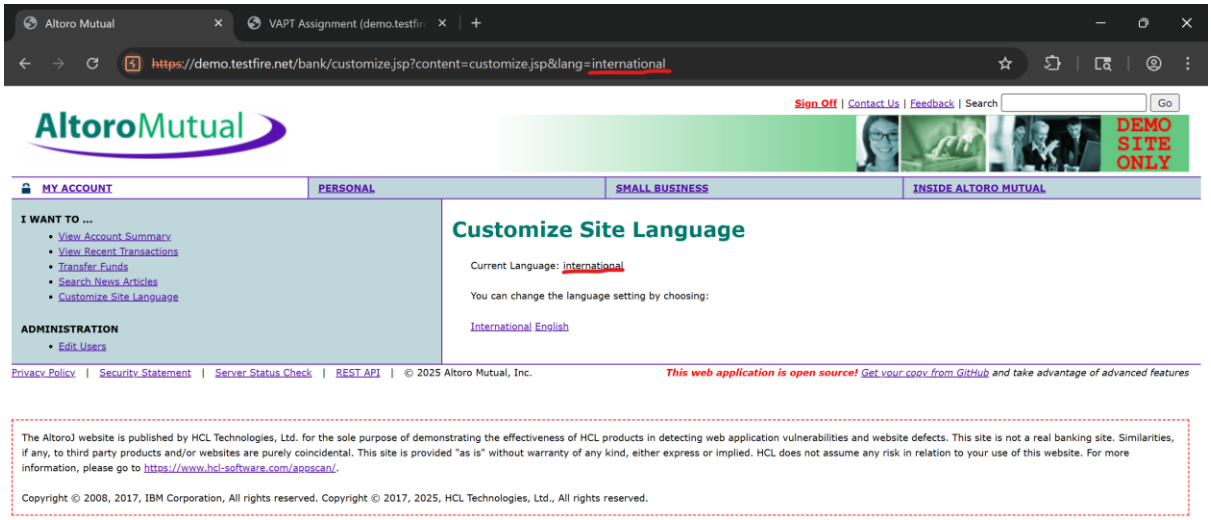
12. Unsupported language value displayed:-

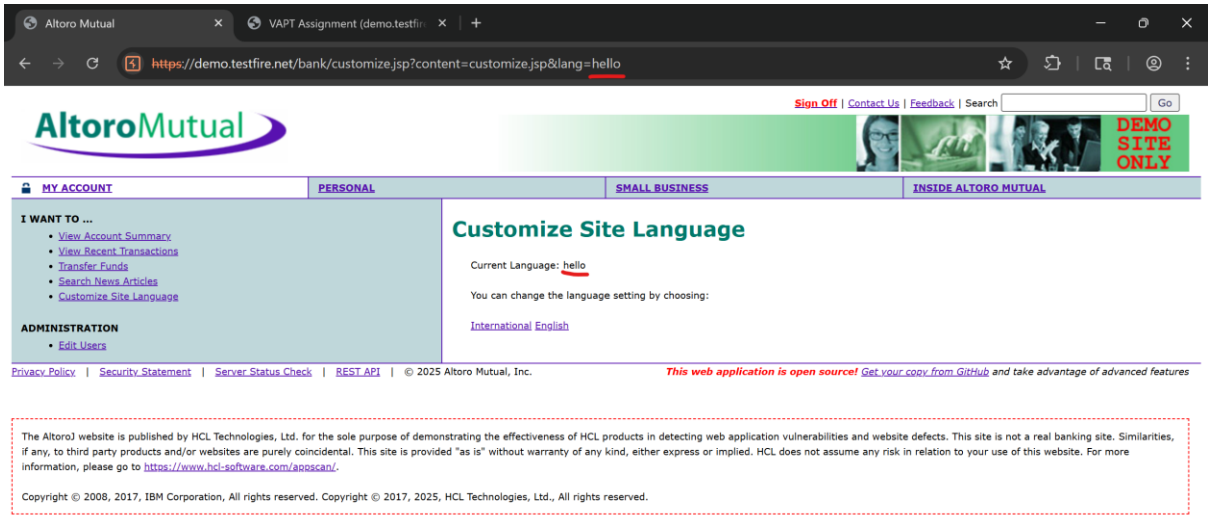
Classification: Functional issue | No demonstrated security impact

The lang parameter on https://demo.testfire.net/bank/customize.jsp?content=customize.jsp&lang=international was reflected as the Current Language even when set to an

unsupported value. The input was reported to be encoded, and no script execution or **SQL injection** was observed. The evidence supports a language selection validation issue without a demonstrated security impact.



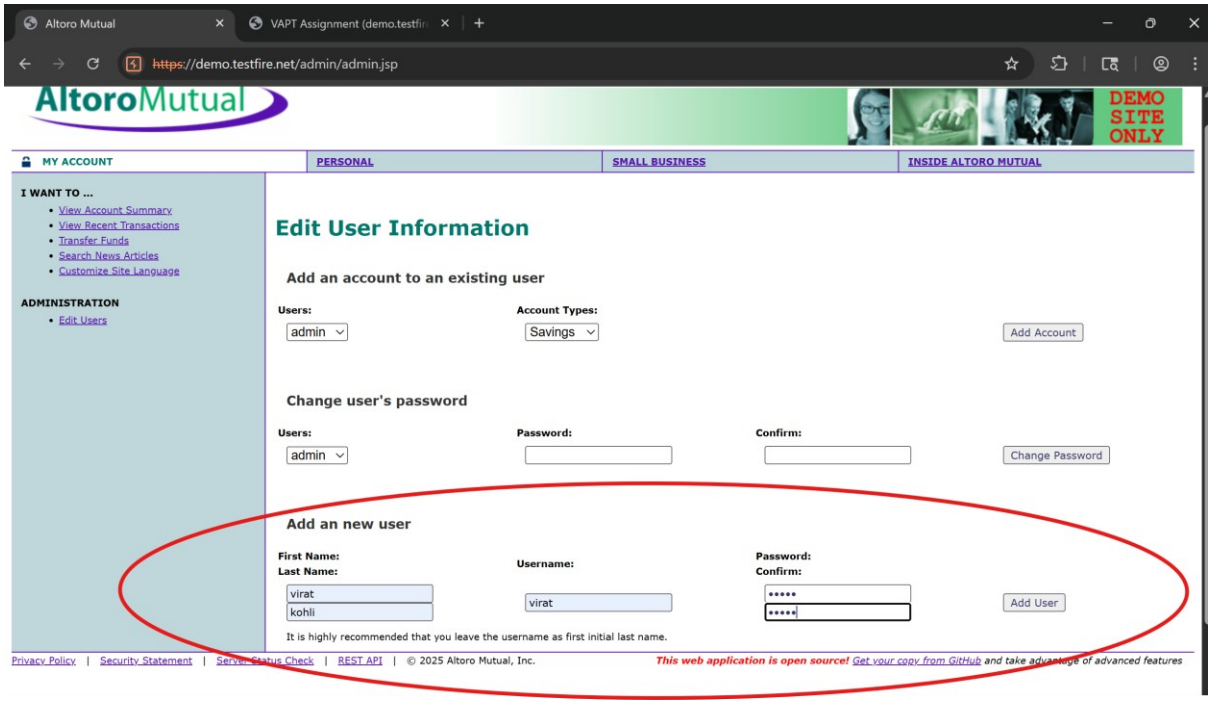


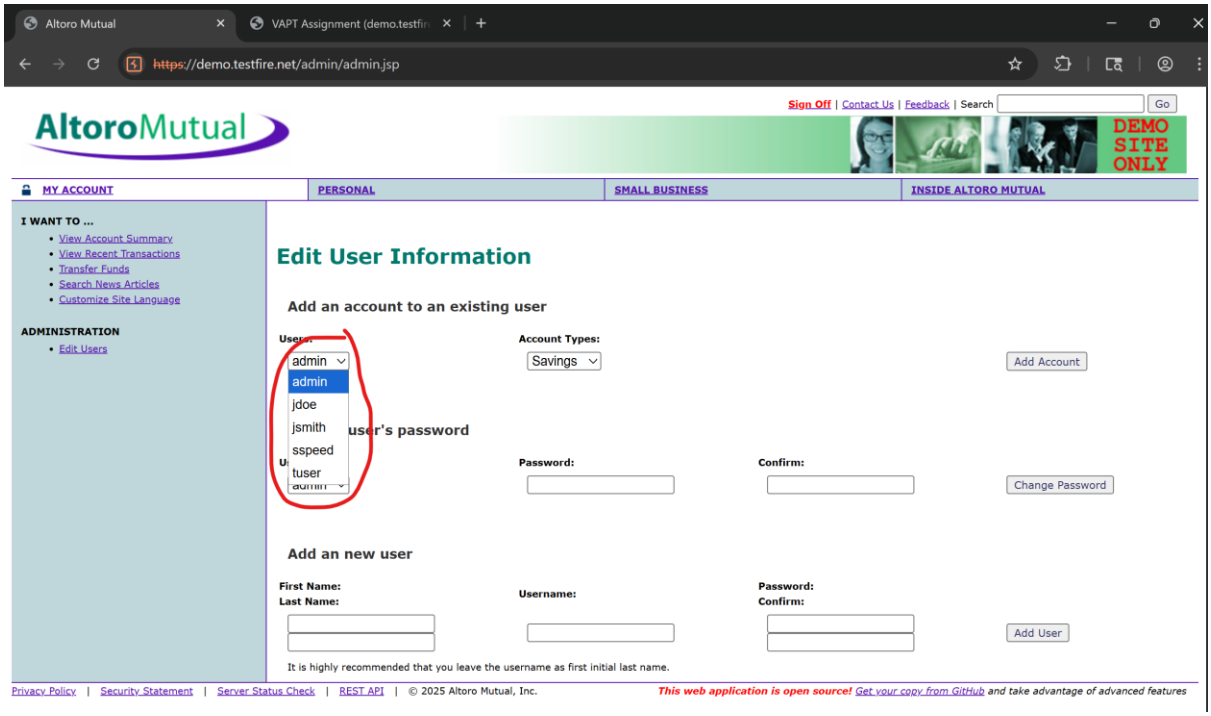


13. User and account creation not reflected:-

Classification: Functional issue | No demonstrated security impact

On https://demo.testfire.net/admin/admin.jsp, attempts by the administrator to add a user or an account did not produce the expected visible result. The new user was not shown in the Users dropdown. This is a functional observation; persistent server-side changes and a security impact were not established.

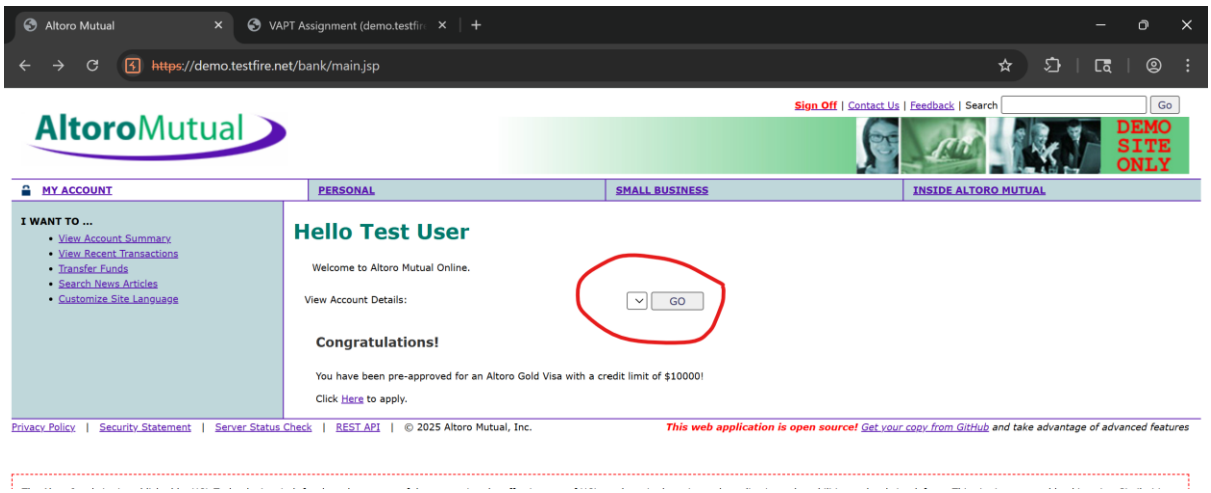




14. Account summary unavailable for test user:-

Classification: Functional issue | No demonstrated security impact

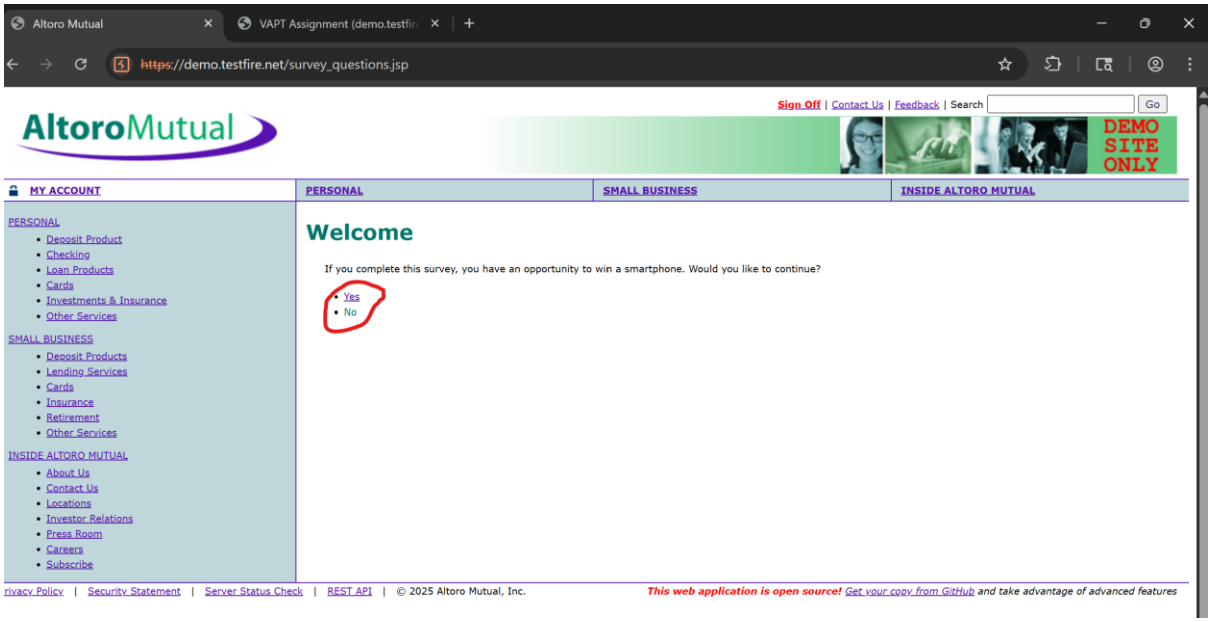
The original test reported inconsistent logins after administrator password changes. The screenshot from https://demo.testfire.net/bank/main.jsp shows the test user with an empty account selection. Administrator password reset capability is not itself an access control flaw, and an empty account list does not demonstrate unauthorised access. The account assignment and expected permissions need to be checked before making a security claim.



15. Survey continues after No selection:-

Classification: Functional issue | No demonstrated security impact

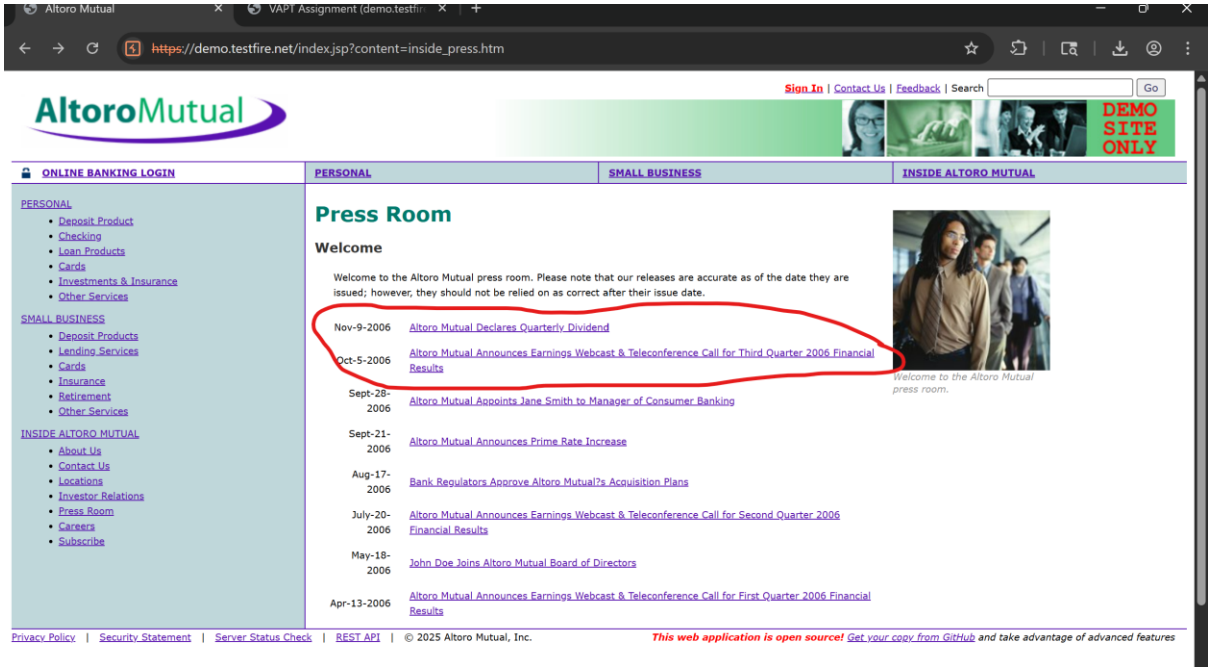
The survey at https://demo.testfire.net/survey_questions.jsp continued after No was selected. This is a workflow or confirmation defect. No security-sensitive consent requirement, protected action, or resulting security impact was established.

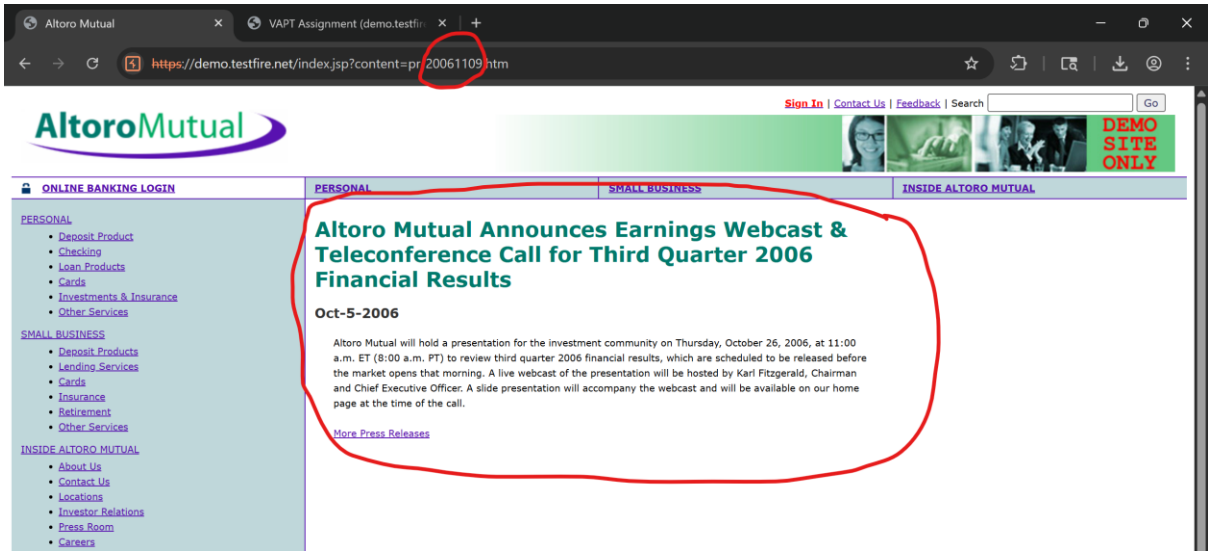


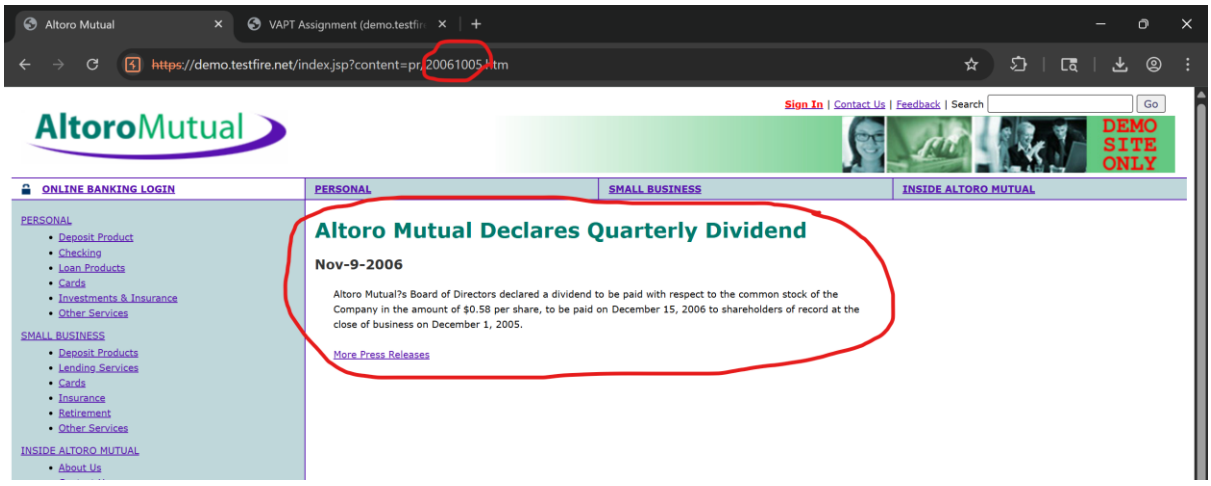
16. Press release content mismatch:-

Classification: Functional issue | No demonstrated security impact

In the Press Room at https://demo.testfire.net/index.jsp?content=inside_press.htm, selecting Nov-9-2006 displayed the Oct-5-2006 release and selecting Oct-5-2006 displayed the Nov-9-2006 release. Other tested dates matched their content. This supports a link or content mapping defect; a backend cause and a security impact were not established.


Altoro Mutual
VAPT Assignment (demo.testfir
https://demo.testfire.net/index.jsp?content=inside_press.htm
AltoroMutual
Sign In | Contact Us | Feedback | Search
Go
DEMO SITE ONLY
ONLINE BANKING LOGIN
PERSONAL
SMALL BUSINESS
INSIDE ALTORO MUTUAL
PERSONAL
Deposit Product
Checking
Loan Products
Cards
Investments & Insurance
Other Services
SMALL BUSINESS
Deposit Products
Lending Services
Cards
Insurance
Retirement
Other Services
INSIDE ALTORO MUTUAL
About Us
Contact Us
Locations
Investor Relations
Press Room
Careers
Subscribe
Press Room
Welcome
Welcome to the Altoro Mutual press room. Please note that our releases are accurate as of the date they are issued; however, they should not be relied on as correct after their issue date.
Nov-9-2006 Altoro Mutual Declares Quarterly Dividend
Oct-5-2006 Altoro Mutual Announces Earnings Webcast & Teleconference Call for Third Quarter 2006 Financial Results
Sept-28-2006 Altoro Mutual Appoints Jane Smith to Manager of Consumer Banking
Sept-21-2006 Altoro Mutual Announces Prime Rate Increase
Aug-17-2006 Bank Regulators Approve Altoro Mutual?s Acquisition Plans
July-20-2006 Altoro Mutual Announces Earnings Webcast & Teleconference Call for Second Quarter 2006 Financial Results
May-18-2006 John Doe Joins Altoro Mutual Board of Directors
Apr-13-2006 Altoro Mutual Announces Earnings Webcast & Teleconference Call for First Quarter 2006 Financial Results
Welcome to the Altoro Mutual press room.
Privacy Policy | Security Statement | Server Status Check | REST API | © 2025 Altoro Mutual, Inc.
This web application is open source! Get your copy from GitHub and take advantage of advanced features

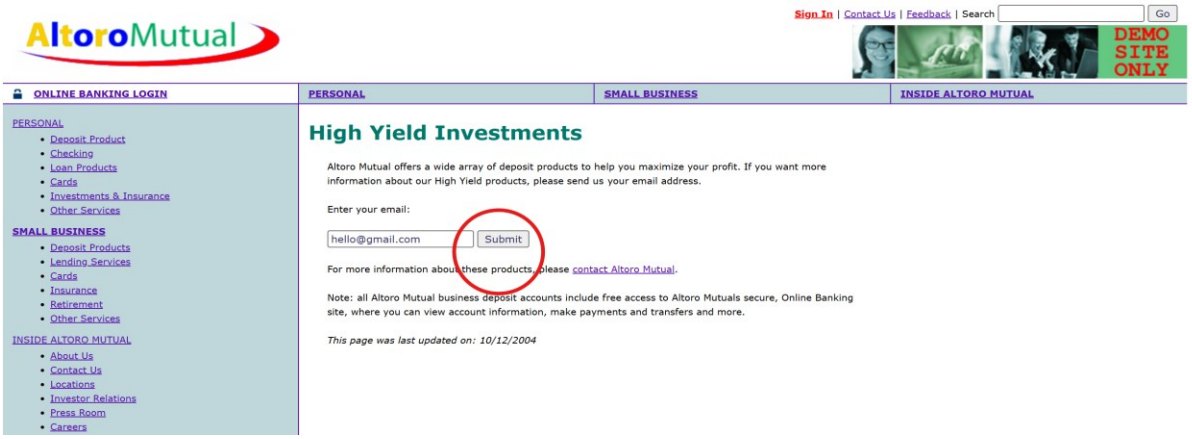

Altoro Mutual
VAPT Assignment (demo.testfir
https://demo.testfire.net/index.jsp?content=pr 20061109 htm
AltoroMutual
Sign In | Contact Us | Feedback | Search
Go
DEMO SITE ONLY
ONLINE BANKING LOGIN
PERSONAL
SMALL BUSINESS
INSIDE ALTORO MUTUAL
PERSONAL
Deposit Product
Checking
Loan Products
Cards
Investments & Insurance
Other Services
SMALL BUSINESS
Deposit Products
Lending Services
Cards
Insurance
Retirement
Other Services
INSIDE ALTORO MUTUAL
About Us
Contact Us
Locations
Investor Relations
Press Room
Careers
Altoro Mutual Announces Earnings Webcast & Teleconference Call for Third Quarter 2006 Financial Results
Oct-5-2006
Altoro Mutual will hold a presentation for the investment community on Thursday, October 26, 2006, at 11:00 a.m. ET (8:00 a.m. PT) to review third quarter 2006 financial results, which are scheduled to be released before the market opens that morning. A live webcast of the presentation will be hosted by Karl Fitzgerald, Chairman and Chief Executive Officer. A slide presentation will accompany the webcast and will be available on our home page at the time of the call.
More Press Releases


Altoro Mutual
VAPT Assignment (demo.testfir
https://demo.testfire.net/index.jsp?content=pr 20061005 htm
AltoroMutual
Sign In | Contact Us | Feedback | Search
Go
DEMO SITE ONLY
ONLINE BANKING LOGIN
PERSONAL
SMALL BUSINESS
INSIDE ALTORO MUTUAL
PERSONAL
Deposit Product
Checking
Loan Products
Cards
Investments & Insurance
Other Services
SMALL BUSINESS
Deposit Products
Lending Services
Cards
Insurance
Retirement
Other Services
INSIDE ALTORO MUTUAL
About Us
Altoro Mutual Declares Quarterly Dividend
Nov-9-2006
Altoro Mutual?s Board of Directors declared a dividend to be paid with respect to the common stock of the Company in the amount of $0.58 per share, to be paid on December 15, 2006 to shareholders of record at the close of business on December 1, 2005.
More Press Releases

17. Email submit button has no visible effect:-

Classification: Functional issue | No demonstrated security impact

On https://demo.testfire.net/high_yield_investments.htm, the email Submit button produced no visible response. Inspection did not find a form element around the controls. This is a functional submission defect without a demonstrated security impact.



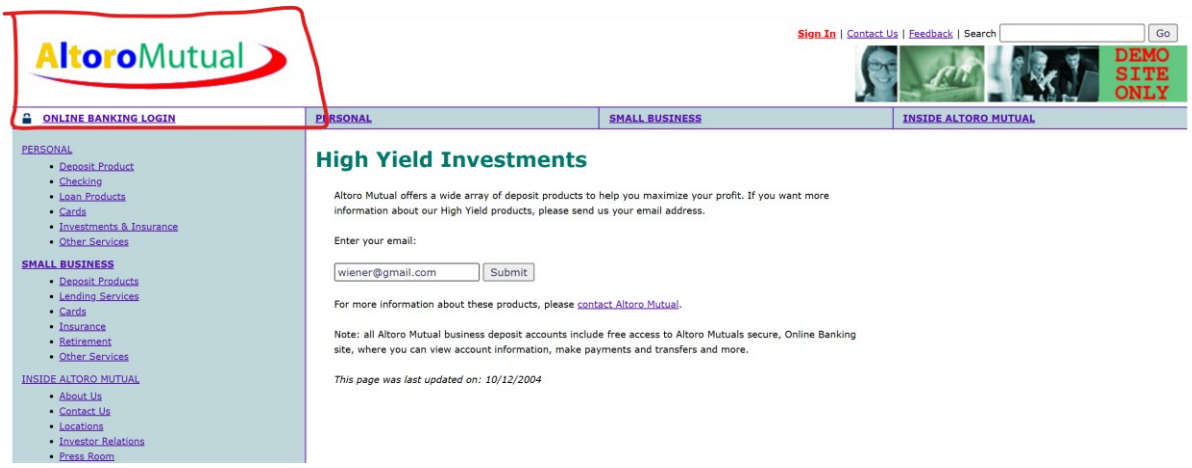


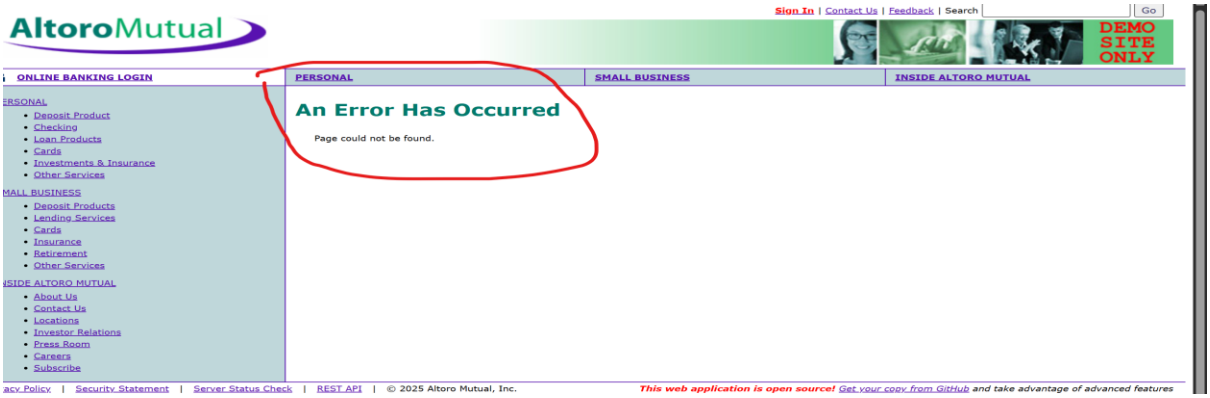
18. Broken investment page image link:-

Classification: Functional issue | No demonstrated security impact

Clicking the indicated image on https://demo.testfire.net/high_yield_investments.htm opened a page not

found response. This is a broken navigation link; no security impact was demonstrated.

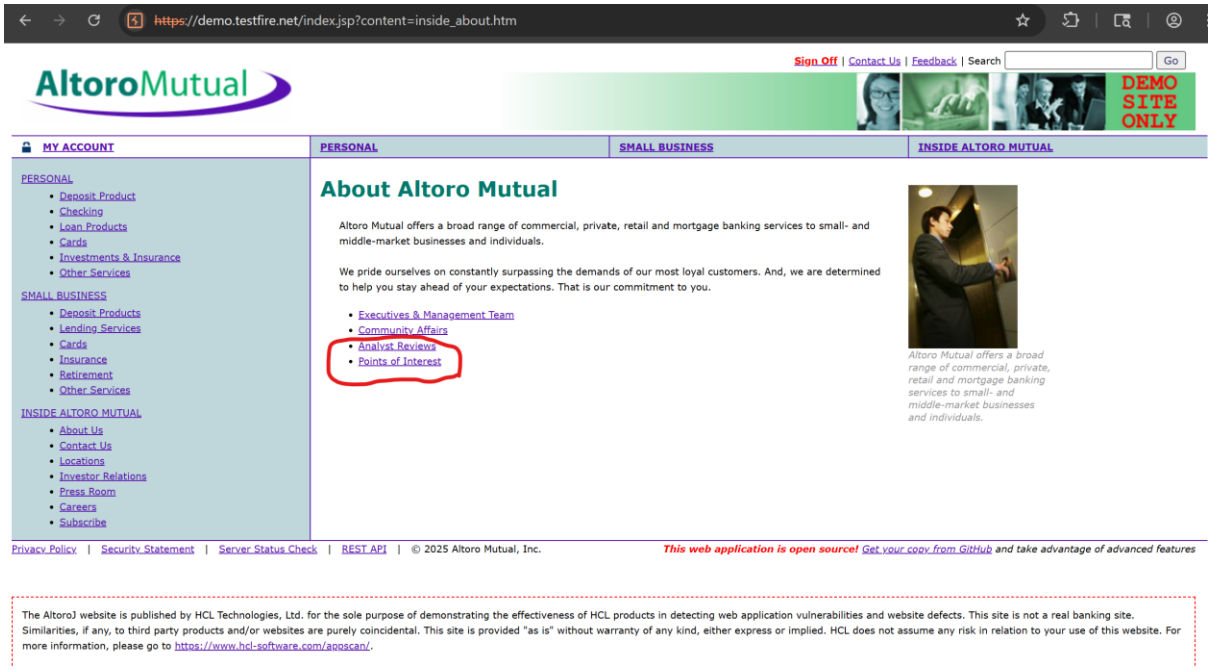


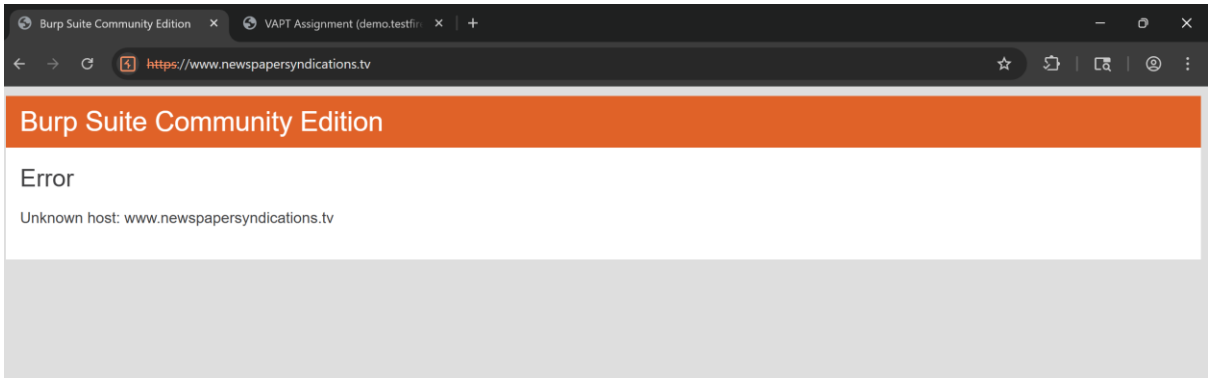


19. Analyst Reviews destination unresolved:-

Classification: Functional issue | No demonstrated security impact

The Analyst Reviews link from https://demo.testfire.net/index.jsp?content=inside_about.htm led to a destination that the proxy could not resolve. This is a broken external destination observation; domain takeover or other security impact was not demonstrated.

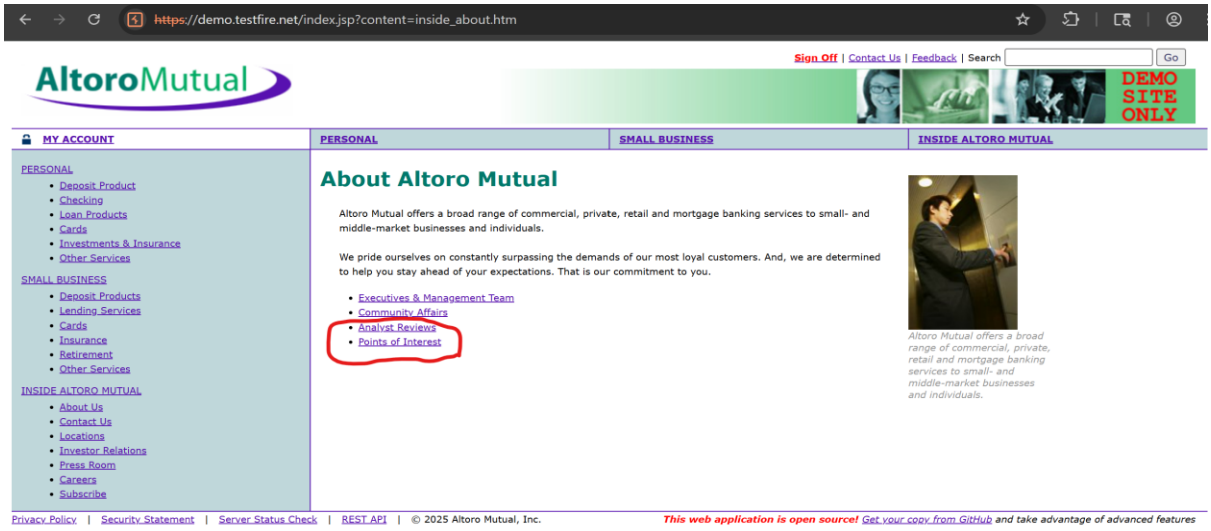


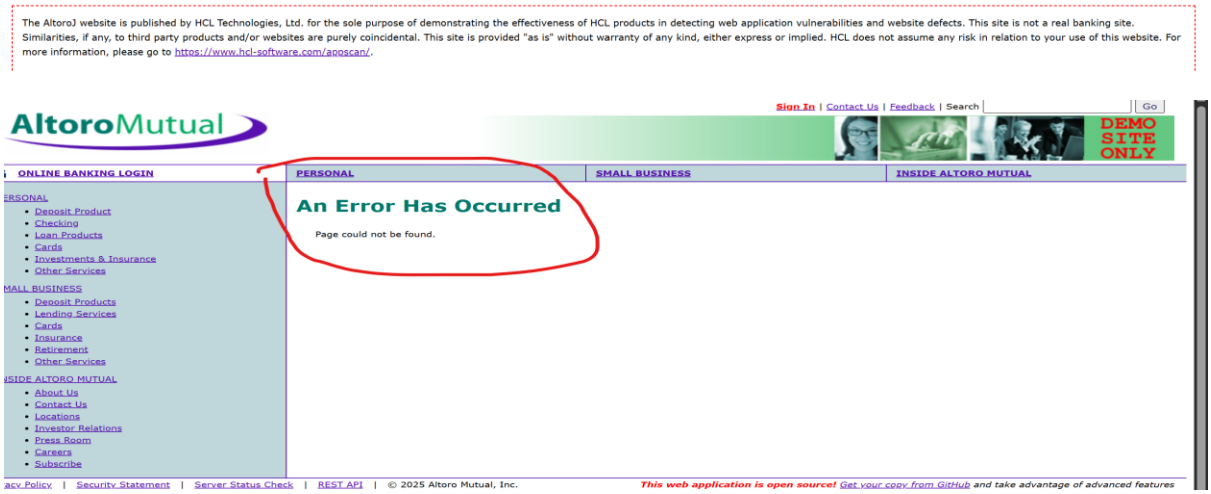


20. Points of interest link unavailable:-

Classification: Functional issue | No demonstrated security impact

The Points of interest link on https://demo.testfire.net/index.jsp?content=inside_about.htm returned a page not found response. This is a navigation defect without a demonstrated security impact.

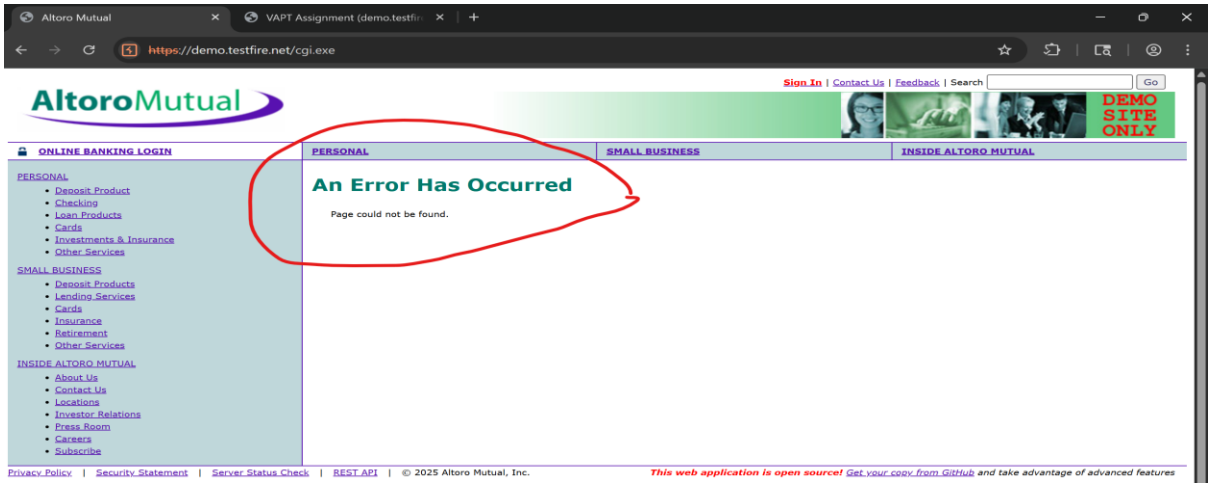




21. Locations page unavailable:-

Classification: Functional issue | No demonstrated security impact

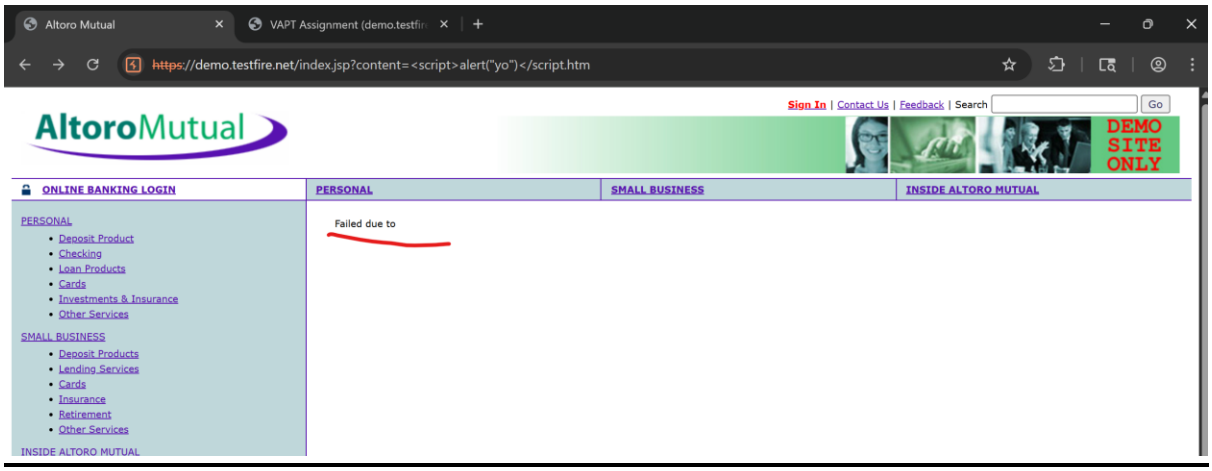
The Locations link to https://demo.testfire.net/cgi.exe returned a page not found response. This is a broken link without a demonstrated security impact.



22. Generic response to malformed content:-

Classification: Other observation | Needs validation

A script-like value was supplied through the content parameter on https://demo.testfire.net/index.jsp. The screenshot shows a generic failure message rather than script execution or sensitive error details. The recorded response alone does not establish XSS or a security-relevant error handling flaw.

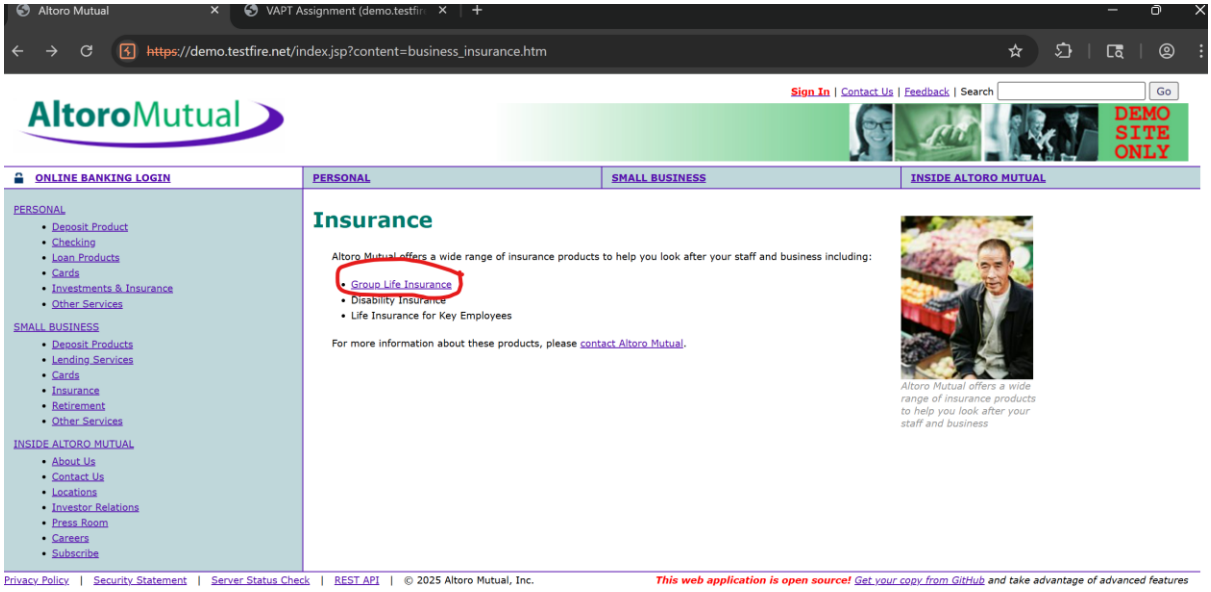


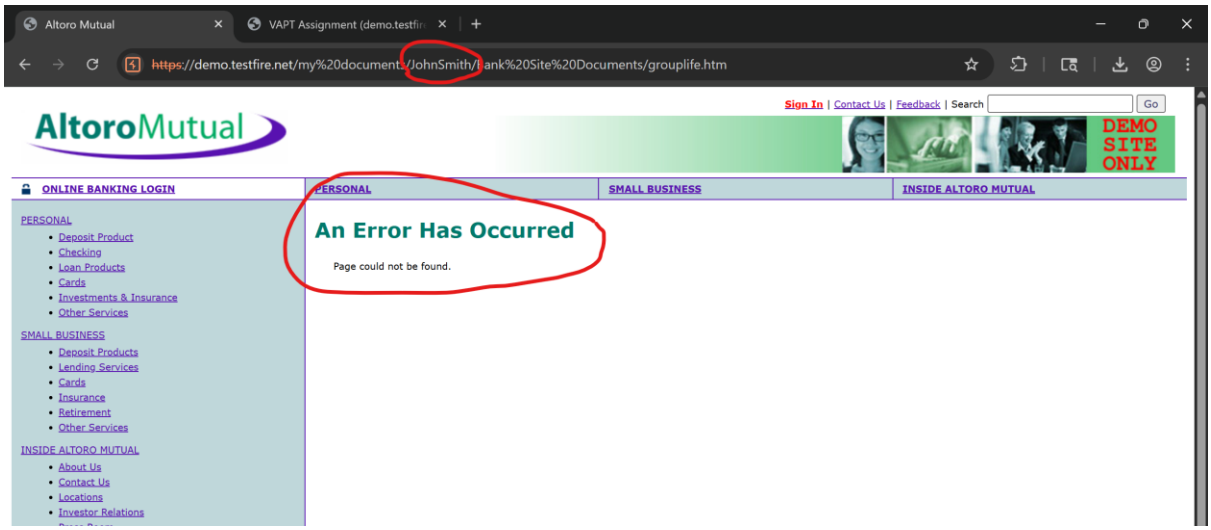
23. Personal name in a broken document URL:-

Classification: Other observation | Informational

The Group Life Insurance link on https://demo.testfire.net/index.jsp?content=business_insurance.htm points to https://demo.testfire.net/my%20documents/JohnSmith/Bank%20Site%20Docu

ments/grouplife.htm. Access returned an error, but the URL contained the name JohnSmith. This is a path metadata observation; no private document contents or unauthorised access were demonstrated.





24. Password copy and paste permitted:-

Classification: Other observation | Not a vulnerability

The password field permitted copying and pasting. This behaviour alone does not demonstrate clipboard leakage, unauthorised password access, or an OWASP Top 10 vulnerability. Allowing paste also supports password manager use.